

Information Disclosure Vulnerability Report

Prepared by: Satyam shiv

Date: June 24, 2026

Task: Locate and document an information disclosure vulnerability within the assigned lab environment.

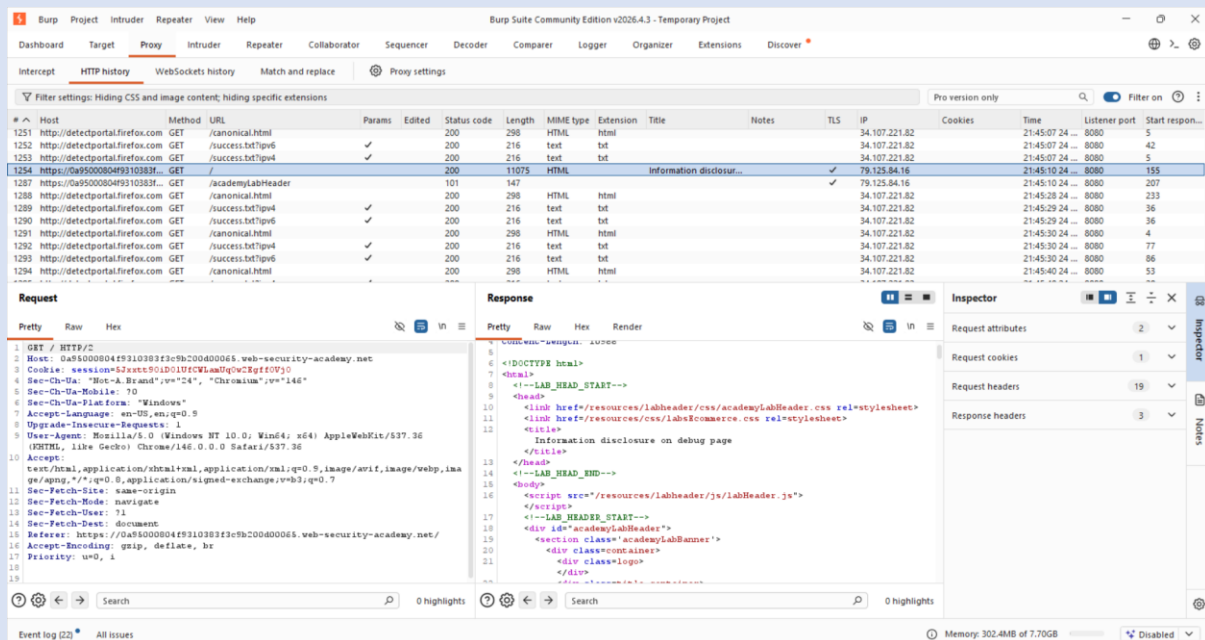
1. Summary of the Issue

During testing, I found that the web application leaks private setup and system details to anyone on the internet. A developer left a hidden link to a debug page inside the website's HTML source code. By opening this page, I was able to see the server's internal settings, usernames, and a private SECRET_KEY.

2. Steps to Reproduce (How I Found It)

Step 1: Analyzing the Website Source Code

I opened the target website and used Burp Suite to capture the traffic. While looking through the HTTP history tab at the website's main HTML response, I scrolled to the bottom and noticed a commented-out HTML link left by a developer.



Step 2: Accessing the Hidden Page

I copied that path (/cgi-bin/phpinfo.php) and added it to the end of the website's URL in my browser. The server allowed me to open it directly without asking for any login details, exposing a massive list of internal PHP configurations.

```
192     </div>
193     <div>
194         
195         <h3>
196             Couple&apos;s Umbrella
197         </h3>
198         
199         $60.25
200         <a class="button" href="/product?productId=20">
201             View details
202         </a>
203     </div>
204 </section>
205 <!-- <a href="/cgi-bin/phpinfo.php">Debug</a> -->
206 </div>
207 </section>
208 <div class="footer-wrapper">
209 </div>
210 </div>
211 </body>
212 </html>
```

Lab: Information disclosure in - x Lab: Information disclosure on - x PHP 7.4.3-4ubuntu2.29 - phpinfo - PortSwigger

https://0a95000804f9310383f3c9b200d00065.web-security-academy.net/cgi-bin/phpinfo.php

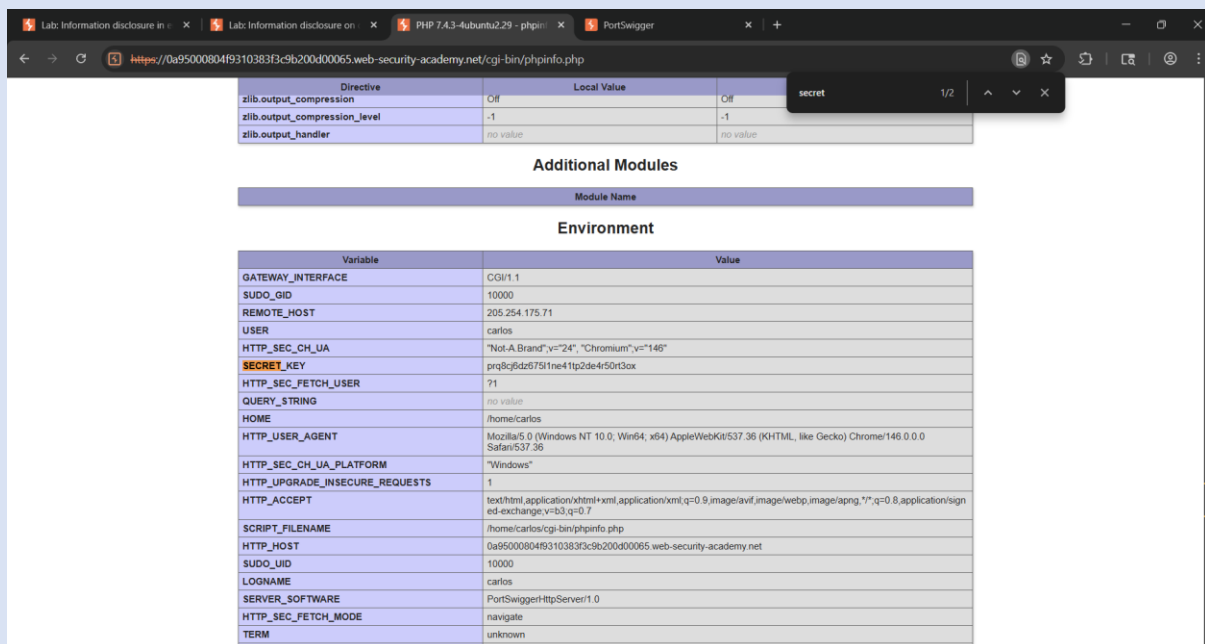
PHP Version 7.4.3-4ubuntu2.29

System	Linux 17d14af0947a 4.14.355-201.714-amzn2-x86_64 #1 SMP Mon Mar 23 17:42:56 UTC 2020 x86_64
Build Date	Mar 25 2025 18:57:03
Server API	CGI/FastCGI
Virtual Directory Support	disabled
Configuration File (php.ini) Path	/etc/php/7.4/cgi
Loaded Configuration File	/etc/php/7.4/cgi/php.ini
Scan this dir for additional .ini files	/etc/php/7.4/cgi/conf.d
Additional .ini files parsed	/etc/php/7.4/cgi/conf.d/10-opcache.ini, /etc/php/7.4/cgi/conf.d/10-pdo.ini, /etc/php/7.4/cgi/conf.d/15-xml.ini, /etc/php/7.4/cgi/conf.d/20-calendar.ini, /etc/php/7.4/cgi/conf.d/20-curl.ini, /etc/php/7.4/cgi/conf.d/20-dom.ini, /etc/php/7.4/cgi/conf.d/20-exif.ini, /etc/php/7.4/cgi/conf.d/20-ftp.ini, /etc/php/7.4/cgi/conf.d/20-gd.ini, /etc/php/7.4/cgi/conf.d/20-gettext.ini, /etc/php/7.4/cgi/conf.d/20-iconv.ini, /etc/php/7.4/cgi/conf.d/20-ldap.ini, /etc/php/7.4/cgi/conf.d/20-openssl.ini, /etc/php/7.4/cgi/conf.d/20-pdo_sqlite.ini, /etc/php/7.4/cgi/conf.d/20-posix.ini, /etc/php/7.4/cgi/conf.d/20-readline.ini, /etc/php/7.4/cgi/conf.d/20-shmop.ini, /etc/php/7.4/cgi/conf.d/20-simplexml.ini, /etc/php/7.4/cgi/conf.d/20-sockets.ini, /etc/php/7.4/cgi/conf.d/20-sysvmsg.ini, /etc/php/7.4/cgi/conf.d/20-sysvsem.ini, /etc/php/7.4/cgi/conf.d/20-xmlreader.ini, /etc/php/7.4/cgi/conf.d/20-xmlwriter.ini, /etc/php/7.4/cgi/conf.d/20-xsl.ini, /etc/php/7.4/cgi/conf.d/99-academy.ini
PHP API	20190902
PHP Extension	20190902
Zend Extension	320190902
Zend Extension Build	API320190902.NTS
PHP Extension Build	API20190902.NTS
Debug Build	no
Thread Safety	disabled
Zend Signal Handling	enabled
Zend Memory Manager	enabled
Zend Multibyte Support	disabled
IPv6 Support	enabled
DTrace Support	available, disabled
Registered PHP Streams	https, ftps, compress.zlib, php, file, glob, data, http, ftp, phar
Registered Stream Socket Transports	tcp, udp, unix, udg, ssl, tls, tlsv1.0, tlsv1.1, tlsv1.2, tlsv1.3

Step 3: Finding the Private Key

Inside this configurations file, I used the browser's search tool (Ctrl + F) to search for the word "SECRET". I quickly found a sensitive environment variable containing the actual text key used by the application.

- **Leaked Variable:** SECRET_KEY
- **Value Found:** prq8cj6dz675l1ne41tp2de4r50rt3ox



Directive	Local Value	Global Value
zlib.output_compression	Off	Off
zlib.output_compression_level	-1	-1
zlib.output_handler	no value	no value

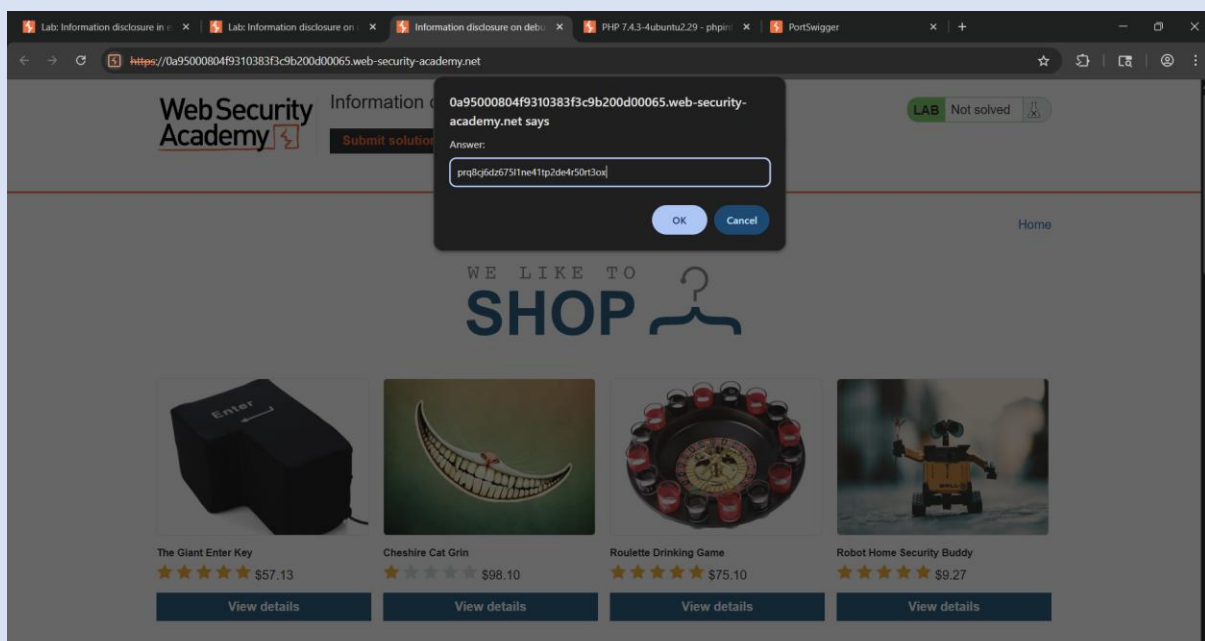
Additional Modules

Module Name
Environment

Variable	Value
GATEWAY_INTERFACE	CGI/1.1
SUDO_GID	10000
REMOTE_HOST	205.254.175.71
USER	carlos
HTTP_SEC_CH-UA	"Not-A.Brand";v="24"; "Chromium";v="146"
SECRET_KEY	prq8cj6dz675l1ne41tp2de4r50rt3ox
HTTP_SEC_FETCH_USER	?1
QUERY_STRING	no value
HOME	/home/carlos
HTTP_USER_AGENT	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
HTTP_SEC_CH-UA-PLATFORM	"Windows"
HTTP_UPGRADE_INSECURE_REQUESTS	1
HTTP_ACCEPT	text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
SCRIPT_FILENAME	/home/carlos/cgi-bin/phpinfo.php
HTTP_HOST	0a95000804f9310383f3c9b200d00065.web-security-academy.net
SUDO_UID	10000
LOGNAME	carlos
SERVER_SOFTWARE	PortSwigger/HTTPServer/1.0
HTTP_SEC_FETCH_MODE	navigate
TERM	unknown

Step 4: Confirming the Impact

To verify that this key was active and dangerous, I submitted it into the lab's answer validation box. The application accepted it immediately and marked the challenge as solved.



Web Security Academy Information disclosure on 0a95000804f9310383f3c9b200d00065.web-security-academy.net

Submit solution

LAB Not solved

Answer:

prq8cj6dz675l1ne41tp2de4r50rt3ox

OK Cancel

WE LIKE TO SHOP

The Giant Enter Key \$57.13

Cheshire Cat Grin \$98.10

Roulette Drinking Game \$75.10

Robot Home Security Buddy \$9.27

Lab: Information disclosure on debug page

APPRENTICE



LAB



Solved



This lab contains a debug page that discloses sensitive information about the application. To solve the lab, obtain and submit the `SECRET_KEY` environment variable.

3. Why is this Dangerous?

- **Exposes Secrets:** Attackers can steal configuration keys like this `SECRET_KEY` to hijack user sessions or bypass security controls.
- **Server Details Leaked:** The page shows the exact operating system version (Linux...amzn2), the local username (carlos), and paths (/home/carlos/). This gives a hacker a clear map of the server to plan a deeper network attack.

4. How to Fix It

1. **Delete the Debug File:** Completely remove the `phpinfo.php` file from the live server.
2. **Clean up Comments:** Ensure code reviews check for and remove hidden comments or layout links (``) before publishing code to production.
3. **Change the Key:** Because the old `SECRET_KEY` was exposed in plaintext, it must be changed immediately to a new random value